

Contentious Chamber

Decision on the merits 149/2023 of November 10, 2023

By a ruling dated May 8, 2024 (2023/AR/1519), the applicant (complainant before the Contentious Chamber) is dismissed from her appeal, which was declared partially inadmissible and partially unfounded.

Case numbers: DOS-2020-05649 and DOS-2021-05271

Subject: Complaints regarding the processing of personal data carried out by an online medical and paramedical appointment booking platform.

The Contentious Chamber of the Data Protection Authority, composed of Mr. Hielke HIJMANS, President, and Messrs. Dirk Van Der Kelen and Yves Pouillet, members, resuming the case in this composition;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter referred to as "GDPR";

Considering the Law of December 3, 2017, establishing the Data Protection Authority (hereinafter "LCA");

Considering the Law of August 8, 1983, organizing a National Register of Natural Persons (hereinafter "LRN");

Considering the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the case files;

Has made the following decision regarding:

Complainant No. 1:

Ms. X1, (DOS-2020-05649);

Complainant No. 2:

Mr. X2, (DOS-2021-05271);

Defendants:

Company Y1, represented by Maîtres Florence Garcet and Claire Vandesande, lawyers, whose office is located at 4000 Liège, rue des Augustins, 32, hereinafter referred to as "the first defendant" (DOS-2020-05649 and DOS-2021-05271);

Company Y2, hereinafter referred to as "the second defendant" (DOS-2020-05649);

Hereinafter collectively referred to as "the defendants".

Decision on the merits 149/2023 — 2/34

I. Facts and Procedure

I.1.

Regarding the complaint of complainant No. 1 (DOS-2020-05649)

1.

On December 4, 2020, complainant No. 1 filed a complaint with the Data Protection Authority (DPA) against the defendants.

2.

In her complaint and the clarifications provided in terms of conclusions and during the hearing (see below), complainant No. 1 reports the following facts.

3.

In early October 2020, wishing to make an appointment with her dentist without calling by phone, complainant No. 1 found that the website [...] (hereinafter "Z" or "the platform" or "the platform Z") allows for direct online appointment booking with health professionals. The contact details of her dentist are listed on the platform, and complainant No. 1 creates an account to be able to make an appointment with her.

4.

Complainant No. 1 reports that it was only after creating her account that she received the information that it was not possible for her to make an appointment with her dentist, as only the contact details of the latter were listed on the site without the possibility of making an appointment with her via the platform itself.

5.

For the proper understanding of this decision, the Contentious Chamber specifies here that the platform "Z" aims to facilitate quick contact between patients and healthcare professionals – including but not limited to doctors – particularly through online appointment bookings. When a patient accesses the platform, two options are available to them:

-

Either only the contact details of the sought practitioner are listed on the platform without the possibility of making an appointment with them via the platform. This is referred to as a "non-registered practitioner/professional." In this case, the patient can make an appointment with this practitioner through their own contact channels based on the contact details listed on the platform. No account is necessary for this purpose.

-

Or it is possible to make an appointment directly via the platform with the sought practitioner. This is referred to as a "registered practitioner/professional" on the platform. To make such an appointment, the patient must create a patient account for which they are asked to provide the following personal data: their last name, first name, email address, phone number, and National Registry Number (NRN).

6. On October 21, 2020, having been unable to make an appointment with her dentist (non-registered) via the platform, complainant No. 1 requests the deletion of her account and the personal data she provided during its creation. In the email sent for this purpose to the address info@[...], complainant No. 1 also...

Decision on the merits 149/2023 — 3/34

regarding her inquiry about the obligation to provide her NRN when creating her account.

7.

Complainant No. 1 states that she did not receive a response to this request for deletion.

8.

Through a company specialized in data protection law, Complainant No. 1 requests on October 22, 2020, the legal bases on which the various data processing operations carried out from the platform are based, the reasons for processing the NRN, as well as the exact identity of the data controller. Complainant No. 1 reports that this request also went unanswered.

9.

In her complaint submitted to the APD on December 4, 2020, which is 1.5 months after sending the aforementioned requests, Complainant No. 1 denounces both the lack of follow-up to her deletion request and her inquiries regarding the legal bases for the various data processing operations carried out by the platform, including her NRN.

10.

On January 5, 2021, complaint No. 1 is declared admissible by the First Line Service (SPL) of the APD based on Articles 58 and 60 of the LCA, and the complaint is transmitted to the Contentious Chamber under Article 62, § 1 of the LCA.

11.

On February 2, 2021, in accordance with Article 96, § 1 of the LCA, the request from the Contentious Chamber to conduct an investigation is transmitted to the Inspection Service (SI).

12.

On May 9, 2022, the investigation by the SI is concluded, the report is attached to the file, and it is transmitted by the SI to the President of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA).

13.

The content of the SI report can be summarized as follows:

-

The first defendant is solely responsible for processing within the meaning of Article 4.7 of the GDPR, to the exclusion of the second defendant. In its analysis, the Inspector General mentions a lack of

clarity regarding the identification of the data controller in the platform's Privacy Policy (Article 13.1.a of the GDPR);

-

As preliminary observations, the SI notes that the platform was evaluated in April 2020 by the General Secretariat. The SI notes that "some shortcomings identified by the General Secretariat do not appear to have been subject to the recommended compliance measures" (page 10 of the investigation report). The SI points out, in this regard, gaps concerning information related to the legal basis for processing (Article 13.1.c of the GDPR) and the data retention period (Article 13.2.a of the GDPR). The SI further notes that the platform processes what it considers a significant volume of health data within the meaning of Article 9 of the GDPR.

-

Based on the facts reported in the complaint, the SI then states that it finds, within the scope of the complaint, a number of breaches of the GDPR:

Decision on the merits 149/2023 — 4/34

- o a violation by the first defendant of Article 12 of the GDPR in that it did not provide any information to complainant No. 1 following her erasure request of October 21, 2020;
- o a violation by the first defendant of Articles 7.3, in fine, and 12.1 of the GDPR in that, as the data controller, it does not make the deletion of a "patient account" as simple as the creation of that account and therefore does not facilitate the exercise of the rights of the data subjects, in this case, the right to erasure of the complainant;
- o a violation by the first defendant of Articles 15.1 and 19 of the GDPR, in that, as the data controller, it did not confirm to complainant No. 1 that the personal data concerning her was no longer being processed nor did it notify complainant No. 1 of the erasure of her data;
- o a violation by the first defendant of Articles 5.1 a), 5.2, and 6 of the GDPR in that, as the data controller, the first defendant cannot validly invoke its legitimate interest (Article 6.1 f) of the GDPR) for the listing of "non-registered" healthcare professionals on the platform;
- o a potential violation by the first defendant in its capacity as data controller of Article 32 of the GDPR in that the use by the first defendant of systems such as Cloudflare, Amazon Web Services, and Runcloud to manage its infrastructure does not constitute an appropriate technical measure to ensure a level of security appropriate to the risk presented by its activity.

14. On June 15, 2022, the Disciplinary Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the case may be examined on the merits.

15. On the same date, the parties are informed by registered mail of the provisions as set out in Article 95, § 2 as well as Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions. The deadline for receiving the defendants' response conclusions has been set for August 10, 2022, that for the reply conclusions of complainant No. 1 for September 1, 2022, and that for the reply conclusions of the defendants for September 23, 2022.

16. The parties are invited to defend themselves regarding the findings and grievances retained by the Disciplinary Chamber:

1 The SI, however, nuances this finding in the introduction of its report indicating that it has observed certain aspects without conducting a complete review of all aspects related to the security obligation of processing.

2 In the context of its own assessment, the Disciplinary Chamber is free to retain one or another finding from the inspection to include in the list of grievances on which it asks the parties to defend themselves in the letter based on Article 98 of the aforementioned LCA. No other conclusion can be drawn from the abandonment of one or another grievance than the fact that the Chamber...

Decision on the merits 149/2023 — 5/34

-

The qualification of the first defendant as solely responsible for processing within the meaning of Article 4.7 of the GDPR;

-

A breach of Articles 13.1. a), 13.1 c) and 13.2 of the GDPR by the first defendant in that the Privacy

Policy of the platform does not adequately mention the identity and contact details of the data controller (Article 13.1. a) of the GDPR), does not mention the legal basis for the data processing carried out – including health data within the meaning of Article 4.19 of the GDPR – (Article 13.1. c) of the GDPR) and does not mention the retention periods for the processed personal data (Article 13.2. a) of the GDPR more specifically);

-
A breach of Article 12 of the GDPR in that the first defendant provided no information to complainant No. 1 following her request to exercise the right to erasure;

-
A breach of Articles 7.3 in fine and 12.1 of the GDPR, in that the first defendant did not make the deletion of a "patient account" as simple as the creation of that account (it is therefore not as simple to withdraw consent as it is to give it) and consequently does not facilitate the exercise of the rights of the data subjects;

-
A breach of Articles 5.1. a), 5.2. and 6 of the GDPR in that the legitimate interest invoked by the first defendant as a legal basis for processing the referenced but "non-registered" professionals on the platform is not validly invoked.

17

The Contentious Chamber also invites the parties to present their arguments regarding the legal basis for the processing by the first defendant of the NRN questioned by complainant No. 1 in her complaint. The Contentious Chamber further informs the parties that a complaint concerning the same issue is also pending before the Contentious Chamber (DOS-2021-05271 – complaint No. 2 hereafter).

18.

On August 2, 2022, the first defendant agrees to receive all communications related to the case electronically. She requests a copy of the file (Art. 95, §2, 3° LCA) in the same correspondence, which is transmitted to her on August 4, 2022.

The Contentious Chamber does not find it appropriate to conclude the parties in this regard. It cannot be inferred that the Contentious Chamber confirms compliance with the GDPR on these aspects. In light of this specific assessment, the Contentious Chamber specifies that the LCA does not require it to resort to the Inspection Service. Indeed, the Contentious Chamber sovereignly decides whether an investigation is necessary or not following the filing of a complaint (Article 63, 2° of the LCA and Article 94, 1° of the LCA). In this sense, Article 94, 3° LCA explicitly provides that once seized, the Contentious Chamber can handle the complaint without resorting to the Inspection Service. It thus has a power of appreciation of the complaint that is independent of the inspection (Market Court (19th ch. A), December 7, 2022, 2022/AR/560 and 2022/AR/564; Market Court (19th ch. A), December 7, 2022, 2022/AR/556).

Decision on the merits 149/2023 — 6/34

19.

On August 10, 2022, complainant No. 1 requests a copy of the file (Art. 95, §2, 3° LCA), which is transmitted to her on August 11, 2022.

20.

On August 10, 2022, the Contentious Chamber receives the response conclusions from the first defendant. The first defendant having submitted reply and summary conclusions, her arguments are summarized in point 22 below.

21.

On September 1, 2022, the Contentious Chamber receives the reply conclusions from complainant No. 1. In summary, she defends the following:

-

The first and second defendants are joint data controllers (Article 4.7. of the GDPR) given a set of elements from which it results that the second defendant is not merely an investor in the first defendant's project;

-

The identification of the data controller in the Privacy Policy of the platform is not sufficiently clear and does not meet the requirements of Article 13.1. a) of the GDPR as the first defendant is not mentioned as such. Only two natural persons, administrators of the first defendant, are listed in the contact details;

-

Article 13.1. c) of the GDPR is not respected in that the Privacy Policy of the platform does not mention the legal bases for each individualized processing, limiting itself to mentioning Article 6.1. of the GDPR in its entirety and making no reference to Article 9.2. a) of the GDPR for the various health data processing carried out via the platform;

-

The Privacy Policy of the platform does not contain information on the retention periods of the data (Article 13.2. a) of the GDPR);

-

Having not been informed of the measures taken following her request for erasure, there has been a breach of Article 12.3. of the GDPR;

-

Articles 7.3. in fine and 12.2. of the GDPR are violated as the deletion of an account proves to be more complex than its creation. Furthermore, two distinct procedures coexist to exercise the right to erasure on the one hand and to exercise the other rights on the other;

-

Complainant No. 1 indicates that she fully aligns with the reasoning of the SI regarding the invalidity of the legitimate interest (Article 6.1.f) of the GDPR) for the processing of the personal data of non-registered practitioners such as her dentist and thus shares the finding of a violation of Articles 5.1.a), 5.2. and 6 of the GDPR by the defendants;

Decision on the merits 149/2023 — 7/34

-

Her complaint is admissible, including regarding the processing of her National Registration Number (NRN), as the legal principle of "ne bis in idem" invoked by the first defendant is inapplicable in this case.

-

Regarding the legality of the processing of the NRN, complainant No. 1 emphasizes that the processing of the NRN is generally prohibited except in the cases provided for by the Law of August 8, 1983, organizing a National Register of Natural Persons (LRN – Article 5) and is generally subject to the authorization of the Minister of the Interior (Article 8.1). The exemption from authorization provided for in Article 8.3 of the LRN, invoked by the first defendant, does not apply since the introduction of the NRN on the platform neither allows for the identification nor the authentication of the person as required by said Article 8.3.

22.

On September 23, 2022, the Contentious Chamber received the reply and summary conclusions of the first defendant. In summary, it defends the following.

-

The mere fact that the second defendant acts as an investor/shareholder does not imply ipso facto that it is responsible for processing in the sense of Article 4.7 of the GDPR. In fact, the second defendant has made no decisions regarding either the purposes or the means of the personal data processing carried out within the framework of the platform;

-

Emphasizing that the SI does not formally identify any breaches of Articles 13.1a), 13.1c), and 13.2 of the GDPR in relation to the platform's Privacy Policy, the first defendant nonetheless states (without acknowledging any breach) that it intends to draft a new Privacy Policy that will clarify the information elements concerned by the aforementioned articles;

-

It has indeed complied with the request for deletion from complainant No. 1, but the email confirming the deletion has not been sent to her;

-
It is no less easy to delete an account than to create one, as both procedures, while not formally identical, are carried out in several steps and require active efforts in both cases (Article 7.3, last part);

-
The action of the Data Protection Authority regarding the legality of the data processing of non-registered professionals is inadmissible. According to the first defendant, the complaint of complainant No. 1 does not concern this issue at all, and it should have been the subject of a separate procedure. The first defendant believes it does not have to justify itself regarding this in the context of the present procedure and towards complainant No. 1. In the alternative, it sets out the reasons for which it...

Decision on the merits 149/2023 — 8/34

considers that it can rely on its legitimate interest within the meaning of Article 6.1(f) of the GDPR to justify these processing activities (see also below point 88).

-
Regarding the question of the lawfulness of the processing of the NRN, it is surprised that this question can be the subject of two distinct proceedings (both in the context of complaint no. 1 and complaint no. 2 – see below and point 32), emphasizing that it has already concluded on this issue in the context of complaint no. 23. Pursuing a party for identical facts without having provided a definitive solution to the first dispute is, in its view, incompatible with the right to a fair trial enshrined in Article 6 of the European Convention on Human Rights (ECHR). Therefore, the first defendant considers the request of complainant no. 1 (and the APD) inadmissible on this point. Alternatively, the first defendant refers to the conclusions it submitted in the context of complaint no. 2 on this aspect (point 46).

23.

On August 2, 2023, the Contentious Chamber notifies the parties that the hearing will take place on September 15, 2023.

24.

In the same letter, the parties are informed that on June 14, 2023, the Contentious Chamber adopted decision 75/2023⁴. Given this decision⁵ unknown to the parties at the time they were invited to conclude, the Contentious Chamber gives the parties the opportunity to submit additional conclusions regarding its position in this decision 75/2023, particularly on aspects that would be relevant in light of complaint no. 1, until August 31, 2023.

25.

On August 31, 2023, in response to the opportunity given to it, the first defendant submits final conclusions.

26.

It specifies that these replace the reasoning it developed in its previous conclusions regarding the invoked lawful basis of legitimate interest (Article 6.1(f) of the GDPR) for the processing of data of "non-registered" healthcare professionals. The first defendant maintains that it was justified in relying on Article 6.1(f) of the GDPR to process the data of non-registered healthcare professionals.

27.

Nevertheless, the first defendant indicates that, following diligent legal monitoring, it became aware as early as the summer of the Contentious Chamber's decision 75/2023.

3 The Contentious Chamber clarifies in this regard that the present decision addresses, in chronological order of the introduction of each complaint, first the course of the procedure related to complaint no. 1 introduced in 2020 and then the course of the procedure related to complaint no. 2 filed in 2021. However, since complaint no. 2 was not sent to the inspection service whose report was communicated to the Contentious Chamber on February 9, 2022, the parties to this second complaint were invited to conclude before the parties to complaint no. 1, even though complaint no. 2 was thus introduced after complaint no. 1.

4 <https://www.autoriteprotectiondonnees.be/publications/decision-quant-au-fond-n-75-2023.pdf>

5 It was also specified to the parties that an annulment appeal had been filed against this decision before the Market Court. See also the mention made in the decision published upon the introduction of

the appeal:

<https://www.gegevensbeschermingsautoriteit.be/publications/beslissing-ten-gronde-nr.-75-2023.pdf>.

Decision on the merits 149/2023 — 9/34

and having decided to rely henceforth on the consent of the said professionals and having initiated a process to collect the consent of the latter as of the summer. The first defendant also submits the latest version of the Privacy Policy of the platform published online in August 2023, which now refers to the aforementioned request for consent from unregistered professionals.

28.

On September 15, 2023, complainant No. 1 and representatives of the first defendant are heard by the Contentious Chamber, with the second defendant not appearing. They each present the arguments developed in terms of conclusions. At the invitation of the Contentious Chamber, the first defendant demonstrates the procedures for creating and deleting an account from the platform. They also present the test version of the platform, which will now operate without requesting the NRN, the first defendant renouncing, in light of the two complaints in particular, to work with this identifier. They confirm what they had indicated in conclusion, namely the gradual collection of consent from unregistered healthcare professionals and the abandonment of the legal basis of legitimate interest.

29.

On September 28, 2023, the minutes of the hearing are submitted to the parties present at the hearing. The second defendant receives a copy for information.

30.

As of October 6, 2023, the Contentious Chamber receives no remarks regarding the minutes from the first defendant and complainant No. 1 present at the hearing.

I.2. Regarding the complaint of complainant No. 2 (DOS-2021-05271)

31.

On July 31, 2021, complainant No. 2 files a complaint (hereinafter complaint No. 2) with the APD against the first defendant.

32.

In his complaint, complainant No. 2 reports that he has noticed that in order to make an appointment on the "Z" platform, it is mandatory to provide his NRN at the time of account creation, without which no appointment can be made, and that this practice seems to him to be contrary to the law.

33.

Complainant No. 2 submits the email he sent to the first defendant on July 17, 2021, in which he emphasizes that he believes (sic) "it is strictly prohibited by law for a private company like yours to request the National Number. You are asked to remove this mandatory field for making an appointment."

34.

On the same day, the first defendant responds to him that (sic) "your national number is requested as a security measure and it is completely encrypted in our database, thus unusable by a third party. A national number is much more difficult to guess by anyone than an email address and therefore more secure. Especially in the context of an application related to healthcare."

Decision on the merits 149/2023 — 10/34

35.

As mentioned in point 32, complainant No. 2, dissatisfied with the response received, filed a complaint with the Data Protection Authority (DPA) on July 31, 2021.

36.

On August 16, 2021, his complaint was deemed admissible by the SPL of the DPA based on Articles 58 and 60 of the LCA and forwarded to the Litigation Chamber under Article 62, § 1 of the LCA.

37.

The complaint does not indicate that complainant No. 2 communicated his National Registration Number (NRN) to the first defendant. On the contrary, it appears that complainant No. 2 refrained from creating an account on the grounds that his NRN was requested. In its conclusions (point 46 below), the first defendant states that it is unable to determine whether complainant No. 2 actually made an appointment via the platform. It adds that, at the very least, when a search is initiated using his name

in the platform's database, it is found that he does not have any account on it. In other words, it seems that the first defendant has not processed personal data related to complainant No. 2 (including his NRN). Therefore, he is not a data subject within the meaning of Articles 4.1 and 77 of the GDPR.
38.

However, this lack of status does not deprive complainant No. 2 of his right to file a complaint with the DPA in support of Article 77 of the GDPR supplemented by Articles 58 and following of the LCA. In this regard, the Litigation Chamber recalls that in a judgment of October 7, 2021, the Court of Cassation stated:

“3. It is undeniably clear from all the aforementioned legal provisions that a data subject has the right to lodge a complaint with the Data Protection Authority against a processing practice that they believe violates their rights under the GDPR (...). This is also the case when the personal data of the data subject themselves have not been processed, but the latter has not obtained the benefit or service because, precisely due to the existence of the practice that presumably constitutes a violation, they refused to consent to the processing.”

6 Article 56 of the LCA states the following: Any person may file a complaint or a written request, dated and signed, with the Data Protection Authority. It must be read in conjunction with the admissibility criteria for complaints detailed in Article 60 of the LCA, which do not include the condition of being a data subject. Nevertheless, there are limits to the admissibility of a complaint related to the complainant's standing as described by the Litigation Chamber in its Note regarding the position of the complainant in the proceedings before the Litigation Chamber and in a number of its decisions. See, for example: Decision on the merits 30/2020 of June 8, 2020 (points 4-7); Decision on the merits 80/2020 of December 17, 2020 (points 44-52); Decision on the merits 63/2021 of June 1, 2021 (points 10-18); Decision on the merits 117/2021 of October 22, 2021 (points 29-35); Decision 49/2022 of April 5, 2022 (points 7-12); Decision on the merits 106/2022 of June 27, 2022. <https://www.autoriteprotectiondonnees.be/publications/note-relative-a-la-position-du-plaignant-dans-la-procedure-au-sein-de-la-chambre-contentieuse.pdf>

7 <https://juportal.be/content/ECLI:BE:CASS:2021:ARR.20211007.1N.4/FR?HiLi=eNpLtDK2qs60MrAutjI2sFJKT01PLUvNK05KLU7OSC3KzcxLL04sLckvyixJzSxRss60MoSqdHd1dw1z9Qt2cg129nAN8vX0cw92DA3xD/IMcfUMAak0gqkkyGYtAFHdLHE=>

8

See in this regard the decision 126/2021 of the Litigation Chamber:

<https://www.autoriteprotectiondonnees.be/publications/classement-sans-suite-n-126-2021.pdf>. It is the Litigation Chamber that emphasizes this.

Decision on the merits 149/2023 — 11/34

39. In this case, complainant no. 2 is indeed denouncing a practice since the NRN is required for any account creation on the platform. This complaint no. 2 is also the second that the APD receives on this matter, the first being that of complainant no. 1 mentioned above (DOS-2020-05649).

40. On January 21, 2022, the first defendant and complainant no. 2 (i.e., the parties involved in this complaint no. 2) are informed by registered mail of the provisions as set out in Article 95, § 2 and Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions. The deadline for receiving the response conclusions from the first defendant was set for March 4, 2022, for the reply conclusions from complainant no. 2 for March 28, 2022, and for the reply conclusions from the first defendant for April 19, 2022.

41. By means of this letter, the first defendant and complainant no. 2 are invited to present their arguments regarding the potential breaches of the GDPR revealed by the practice of processing the NRN denounced, namely a potential breach of Articles 5.1.a) (lawfulness principle), 5.1.c) (data minimization), 5.1.e) (limited retention period), 6.1. (lawfulness), 12 (transparency), 13 (information obligation), 5.2. and 24 (accountability) and 32 (security obligation) of the GDPR as well as the corollary provisions of the LRN, particularly its Article 5 (processing authorization).

42. On February 22, 2022, the first defendant requests a copy of the file (Art. 95, §2, 3° LCA), which is transmitted to them on February 25, 2022.

43. On the same date, the first defendant agrees to receive all communications related to the case

electronically.

44. On March 3, 2022, the Contentious Chamber receives the response conclusions from the first defendant. The first defendant having submitted reply and summary conclusions, the summary of their arguments is presented in point 46 below.

45. On April 13, 2022, the first defendant expresses their request to be heard, in accordance with Article 98 of the LCA.

46. On April 15, 2022, the Contentious Chamber receives the reply and summary conclusions from the first defendant. In summary, they defend the following:

- The processing of the NRN is based on the free consent of the data subject (Article 5.1.a) and 6 of the GDPR): the patient is indeed free to create an account or not. They can also benefit from the information service of the platform and contact the healthcare professional of their choice through the communication channels specific to that professional based on the contact information thus made available;
- When a search is initiated using the name of complainant no. 2 in the platform's database, it is noted that they do not have any account on it.
- The choice to use the NRN is motivated by the absolute necessity to identify the patient in a certain and unique manner. Therefore, there is no infringement of the principle of minimization (Article 5.1.c) of the GDPR) regarding the processing of this NRN;
- The data is only retained for the time necessary for the identification and authentication of the patient and is deleted as soon as the patient unsubscribes from the platform (Article 5.1.e) of the GDPR);
- Regarding the obligations of transparency and information, a specific tab is dedicated to information about the processing of the NRN on the platform (FAQ – privacy). The reasons for which this NRN is requested are described there;
- By opting for the processing of the NRN for the purposes of unique identification and authentication of the data subject, the first defendant has correctly implemented Article 32 of the GDPR, taking into account the risks associated with the nature of the data processed. All processed data (including the NRN) is stored in an encrypted and protected database (Article 32 of the GDPR);
- It follows from the measures put in place (information and particularly security) that the first defendant has complied with the obligations incumbent upon them under Articles 5.2. and 24 of the GDPR;
- Regarding compliance with the LRN, the first defendant only processes the NRN for the purposes of identifying and authenticating the user of the platform. They are therefore exempt from prior authorization from the Minister of the Interior under Article 8.3. of the LRN. The first defendant adds that they do not consult the National Register of natural persons and the data contained therein (page 15 of their conclusions – last paragraph) and that consequently, they are not subject to Article 5 of the LRN.

47. On August 2, 2023, the first defendant and complainant no. 2 are informed that the hearing will take place on September 15, 2023. It should be noted that in response to the invitation to the hearing, complainant no. 2 – who has not submitted conclusions – indicates that their only intention in filing their complaint was to report a potential breach to the APD. As far as necessary, the Contentious Chamber clarifies that this statement does not in any way call into question the admissibility of their complaint (points 36-39) and should not be interpreted as a withdrawal of it. Even assuming it is construed as such by complainant no. 2, the Contentious Chamber remains free to continue examining the complaint notwithstanding such a withdrawal, provided it considers the reported breach sufficiently serious or revealing of the existence of a practice likely to undermine the principles.

Decision on the merits 149/2023 — 13/34

fundamentals of personal data protection as is the case here.

48.

On September 15, 2023, the first defendant is heard by the Contentious Chamber. Complainant No. 2 does not appear.

49.

On September 28, 2023, the minutes of the hearing are communicated to the first defendant. Complainant No. 2 receives a copy for information.

50. As of October 6, 2023, the Contentious Chamber has received no comments from the first

defendant regarding the minutes.

I.3. Regarding the joining of complaints No. 1 and No. 2

51.

By this decision, the Contentious Chamber decides to join complaints No. 1 and No. 2, which it considers to be linked by such a close relationship that there is an interest in making a single decision regarding them in order to ensure the consistency of its decisions. Although the two complaints are filed by distinct complainants (No. 1 and No. 2), they nonetheless target the same platform and additionally raise a common grievance related to the processing of the NRN as mentioned in points 9 (complaint No. 1) and 32 (complaint No. 2) above. In other words, the objective of consistency pursued by the Contentious Chamber in handling the complaints submitted to it opposes their separate examination.

II. Motivation

II.1. Regarding the qualification of the second defendant (DOS-2020-05649)

II.1.1. The viewpoint of the SI and the parties

52.

As mentioned in point 1, complainant No. 1 files her complaint against both the first and the second defendants, whom she qualifies as joint data controllers within the meaning of Article 4.7 of the GDPR.

53.

Complainant No. 1 is indeed of the opinion that a bundle of serious and consistent indications supports this thesis: (1) in 2018, the second defendant—whose creation and management of websites is part of its areas of activity—massively invested in the project to create the platform both financially and operationally, (2) "Platform Z" identified itself at the time of the reported facts in its Privacy Policy as being co-owned by the first and second defendants, dedicating a page on its site to the latter in its capacity as the sole investor and thus providing it with a genuine showcase, (3) the two companies are closely linked, with two entities of the second defendant being directors of the first defendant.

54.

As reported above, the SI retains the status of data controller solely for the first defendant (point 13). The first defendant shares this analysis and qualifies itself as the sole "data controller" with respect to the data processing carried out by the platform (point 22).

II.1.2. The assessment of the Contentious Chamber

55.

The Contentious Chamber is not bound by the status claimed by the first defendant, nor by that which would be attributed to it by the SI. It must assess the reality of this qualification and, if necessary, dismiss it if its analysis shows that it cannot be upheld.

56.

The Contentious Chamber recalls that a data controller is defined as "the natural or legal person or any other entity that alone or jointly with others determines the purposes and means of the processing of personal data" (Article 4.7 of the GDPR). This is an autonomous concept specific to data protection regulation, the assessment of which must be based on the criteria it sets forth: the determination of the purposes of the relevant data processing as well as that of the means thereof.

57.

The Contentious Chamber also recalls that the essential criterion for there to be— as argued by complainant No. 1—joint responsibility for processing is the joint participation of two or more entities in determining the purposes and means of a processing operation. More specifically, joint participation must encompass, on the one hand, the determination of the purposes and, on the other hand, the determination of the means. Joint participation in this determination implies that more than one entity exerts a determining influence on the question of whether, for what purpose, and how the processing takes place. In practice, joint participation may take the form of a common decision made by two or more entities or result from converging decisions adopted by them regarding the essential purposes and means of the processing.

58.

In this case, the Contentious Chamber notes that the elements provided by complainant No. 1 do indeed show, as highlighted by the SI and not contested by the first defendant, that the second

defendant invested in the project to create the platform by the first defendant (then a young start-up). However, the status of joint data controller requires, as previously noted, participation in the determination of the purposes and means of the processing operations. The mere act of financially supporting a project does not necessarily imply that there is a determination of these purposes and means.

Decision on the merits 149/2023 — 15/34

purposes and means through common or converging decisions of the defendants regarding data processing. When, in its Guidelines on the concepts of controller and processor, the EDPB emphasizes that all types of partnership, cooperation, or collaboration do not imply that the entities are joint controllers of the processing, it presupposes that these entities each play a role concerning data processing; a role that, depending on the case, will lead to the qualification of joint controller or not. In this case, the Contentious Chamber finds that there is no evidence of any role of the second defendant concerning the data processing as such. The participation of the second defendant is financial, and neither the documents produced by complainant No. 1 nor the findings of the SI allow the Contentious Chamber to conclude that the second defendant effectively participated in determining the purposes and means of the data processing carried out by the platform.

59.

In conclusion of the above, the Contentious Chamber concludes that the second defendant is not a controller (joint) within the meaning of Article 4.7 of the GDPR concerning the data processing of the platform.

60. The Contentious Chamber notes that during the proceedings, the first defendant clarified the identification and contact details of the data controller (Article 13.1.a of the GDPR) in its Privacy Policy by now including a clause that no longer mentions the names of the individuals who were its administrators at the time. It also removed the mention of "co-owners of the platform" concerning them. This information, foreign to the qualifications of roles in data protection, does not necessarily belong in a privacy policy and risks at least creating confusion.

II.2. Regarding the breach of Article 12.3 of the GDPR by the first defendant: the absence of information regarding the follow-up of the request to exercise the right to erasure of complainant No. 1 (DOS-2020-05649)

II.2.1. The viewpoint of the SI and the parties

61.

As stated in points 7, 9, and 21 above, complainant No. 1 denounces the lack of response from the first defendant to her request for the deletion of the patient account she had created and all personal data concerning her that she had provided at the time of its creation.

62.

In its investigation report (point 13), the SI indicates that it was able to review a screenshot that would attest that complainant No. 1 is no longer listed in the database of the first defendant. Nevertheless, the SI notes that the first defendant acknowledges – as it states in its conclusions (point 22) – that it did not confirm to complainant No. 1 that her personal data had indeed been deleted.

II.2.2. The assessment of the Contentious Chamber

63.

It is therefore undisputed that the first defendant refrained from providing complainant No. 1 with information on the measures taken following her request for deletion in a timely manner and, in any case, within the one-month period from the receipt, on October 21, 2020, of her request as required by Article 12.3 of the GDPR.

64.

The Contentious Chamber emphasizes in this regard that responding to the exercise of the right to erasure of the data subject entails not only the obligation to delete the data concerning her when the conditions for such deletion are met (Article 17.1.b of the GDPR in this case – withdrawal of consent) but also the obligation to inform the data subject about the measures taken following the erasure request, in a timely manner and, in any case, within the one-month period from the receipt of the request (Article 12.3 of the GDPR).

65.

In support of the above, the Contentious Chamber concludes that there has been a breach of Article 12.3 of the GDPR by the first defendant.

66.

The Contentious Chamber notes that the deletion request from complainant No. 1 is a consequence of the fact that she could only ascertain that the dentist she was trying to contact was not registered on the platform after creating her account (in October 2020). In this regard, complainant No. 1 informed the APD on January 9, 2021, that following a change on the site, a pop-up now alerted the patient that the practitioner is not registered on the platform. Upon receiving the complaint on February 2, 2021, the SI indicates that it was unable to ascertain the situation that complainant No. 1 claims to have faced. The first defendant, for its part, defends that this pop-up has always existed.

67.

The Contentious Chamber is unable to ascertain any potential breach of the GDPR that would arise from the situation described by complainant No. 1. Nevertheless, it insists, without this constituting any corrective measure or sanction within the meaning of Article 100 of the LCA, that it must be perfectly clear to the patient that the creation of an account is only required if they can contact a practitioner registered on the platform through it. Thus, the information regarding whether a practitioner is registered or not (and therefore the information that it is or is not possible to make an appointment with them via the platform) must be accessible before the creation of any account. Failing this, the respect due by the first

Decision on the merits 149/2023 — 17/34

the defendant's obligation of transparency¹² and her duty of loyalty could be questioned (Articles 12.1 and 5.1. a) of the GDPR). The Contentious Chamber notes in this regard that the first defendant specified that, in addition to the pop-up in place, it is now explicitly provided in her Privacy Policy, following a modification made during the proceedings, that it is not necessary to create an account to consult the contact details of healthcare professionals, whether they are registered or not.

68.

Regarding more generally the data deletion policy and data retention periods, the Contentious Chamber recalls that data protection authorities are of the opinion that both the information elements provided in §1 of Articles 13 and 14 of the GDPR and those provided in §2 of these same articles must be communicated to the data subjects¹³. Thus, the data retention periods provided for in Article 13.2. a) and 14.2. a) of the GDPR must always be brought to the attention of the data subjects. The Contentious Chamber notes in this regard that the first defendant has modified her Privacy Policy during the proceedings and that it now provides for retention periods based on categories of processing.

II.3. Regarding the breach of Article 7.3. in fine of the GDPR and Article 12.1. of the GDPR by the first defendant (DOS-2020-05649): the withdrawal of consent and the facilitation of the exercise of rights

II.3.1. The viewpoint of the SI and the parties

a) Regarding the withdrawal of consent (Article 7.3. in fine)

69.

According to its investigation report (point 13), the SI concludes that the first defendant violated Article 7.3 in fine of the GDPR in that the first defendant does not make the deletion of a "patient account" as simple as the creation of that account.

70.

The SI details in this regard that creating an account simply requires entering personal data on the platform and securing the account via the receipt of an SMS. In contrast, deleting an account cannot be done directly on the site and requires sending an email to the address `suppression@[...]` or contacting the first defendant from the platform via the chatbot. This difference constitutes, according to the SI, a violation of Article 7.3. of the GDPR, which states that it must be "as easy to withdraw as to give consent."

71.

Complainant No. 1 agrees with the SI's analysis (point 21).

¹² See in this regard point 10 of the Guidelines of the EDPB regarding transparency (Article 29

Working Party, WP 260 adopted by the EDPB during its inaugural session on May 25, 2018: <https://edpb.europa.eu/our-work-tools/our-documents/article-29-working-party-guidelines-transparency-under-regulation-en>) which emphasizes that: "A key aspect of the transparency principle highlighted in these provisions is that the data subject should be able to determine in advance what the scope and consequences of the processing entail so as not to be caught off guard at a later stage regarding how their personal data has been used."

13 See the EDPB Guidelines regarding transparency (<https://edpb.europa.eu/our-work-tools/our-documents/article-29-working-party-guidelines-transparency-under-regulation-en>) already cited (point 23).

Decision on the merits 149/2023 — 18/34

72.

In its conclusions, the first defendant states that at the time of the events, the patient who chose to create an account was invited to provide the identification data already mentioned (point 5). The patient would then receive an SMS with a code that they had to enter on the platform to confirm the creation of their account. Specifically, the patient had to click on a first link, which directed them to a second, then to a third, and finally to a fourth (4-step procedure). Once the last link ("Registration") was clicked, the candidate for account creation was invited to provide the aforementioned data. This was followed by a double verification through the introduction of the received SMS code.

73.

Regarding the deletion of the account, the first defendant states that the withdrawal of consent by the patient required at the time of the events that the latter send an email to the dedicated address for this purpose `deletion@[...]` mentioned in the FAQ "How do I delete my data?". The patient thus had to click on 4 links (4-step procedure), the last link leading them to the deletion email. They could also use the chatbot.

b) Regarding the facilitation of the exercise of rights

74.

The SI further considers that it follows from its finding regarding the withdrawal of consent (point 13) that the first defendant does not facilitate the exercise of the right to erasure provided for in Article 17 of the GDPR, including that of complainant No. 1 (pages 18 and 19 of the SI report). While the SI bases its reasoning on Article 12.2 of the GDPR (page 17 of the investigation report), it concludes that there is a violation of this obligation by mistakenly referring, according to the Contentious Chamber, to Article 12.1 of the GDPR and not to Article 12.2 of the GDPR, which enshrines this obligation.

75.

Complainant No. 1 adds that the fact that the first defendant provides two contact addresses, one general for the exercise of rights `info@[...]` and one specific for the exercise of the right to erasure `deletion@[...]` has not facilitated the exercise of their right to erasure. They point out that, furthermore, the Privacy Policy of the first defendant does not accurately reflect these procedures.

76.

Concluding with regard to Article 12.1 of the GDPR as raised by the SI, the first defendant states that clear information is provided regarding the modalities for withdrawing consent.

II.3.2. The assessment of the Contentious Chamber

a) Regarding the withdrawal of consent (Article 7.3, in fine)

77.

The Contentious Chamber recalls that Article 7.3, in fine, of the GDPR states that the data controller must ensure that it is as easy for the data subject to withdraw as to give their consent, and that this can be done at any time.

Decision on the merits 149/2023 — 19/34

78. As stated by the European Data Protection Board (EDPB) in its Guidelines 05/2020 on consent, the GDPR places significant emphasis on the withdrawal of consent.

79. Nevertheless, the EDPB emphasizes that the GDPR does not specify that the data subject must always be able to give and withdraw consent through the same action (point 113). However, the EDPB is of the opinion that "when consent is obtained electronically solely by a click, a tap, or by swiping the screen, data subjects should, in practice, be able to withdraw that consent in the same manner. When consent is obtained through a user interface specific to the service (for example, via a website, an

application, an account with a login, the interface of an IoT device, or by email), it is evident that a data subject must be able to withdraw their consent through the same electronic interface, as changing interfaces solely for the purpose of withdrawing consent would require unnecessary effort" (point 114).

80. Finally, the EDPB adds that "the GDPR considers the existence of an easy withdrawal as a necessary aspect of valid consent. If the right to withdraw does not meet the requirements of the GDPR, the consent mechanism of the data controller is not compliant with the GDPR. As mentioned in section 3.1 on the condition of informed consent, the data controller must inform the data subject of the right to withdraw consent before they give their consent, in accordance with Article 7, paragraph 3 of the GDPR. As part of the obligation of transparency, the data controller must also inform data subjects of how they can exercise their rights" (point 116).

81. It does not appear to the Dispute Chamber that the process for deleting an account and erasing data by a patient is less straightforward than the steps required to register on the platform. As outlined above by the first defendant (points 72-73), in each case, several steps are necessary. While account creation can be initiated from the platform, it does not occur "with a single click" or a few clicks on it but also requires the receipt of a code via SMS to be re-entered later. Sending an email from the platform as well as the possible use of the chatbot to request the deletion of said account are, according to the Dispute Chamber, not indicative of a less straightforward procedure, as these actions can also be performed from the site and also require several steps. As recalled above (point 79), the procedures by which consent is given and withdrawn do not need to be strictly identical. Upon examination of each of them, the Dispute Chamber is not of the opinion that the account deletion procedure is

14 European Data Protection Board (EDPB), Guidelines 05/2020 on consent under Regulation (EU) 2016/679: https://edpb.europa.eu/sites/default/files/files/file1/edpb_guidelines_202005_consent_fr.pdf
Decision on the merits 149/2023 — 20/34

characterized by a greater degree of difficulty than that of creating the account. The Contentious Chamber concludes that the first defendant is not guilty of a breach of Article 7.3 in fine of the GDPR.

82.

Without this element affecting the preceding conclusion, the Contentious Chamber notes that the first defendant has, during the proceedings, i.e., after the reported facts, added a button that can be clicked to request account deletion and clarified the account deletion request procedure in its Privacy Policy.

b) Regarding the facilitation of the exercise of rights (Article 12.2 of the GDPR)

83.

Regarding Article 12.2 of the GDPR (see the remark in point 74 above), the Contentious Chamber simply notes the following without this constituting any corrective measure and/or sanction within the meaning of Article 100 of the LCA.

84.

The establishment of internal and standardized procedures dedicated to the exercise of the rights of data subjects in terms of data protection is essential and contributes to the effective application of these rights. It certainly facilitates their exercise as required by Article 12.2 of the GDPR. However, when, in the context of such a procedure, a dedicated contact address for exercising these rights exists, data subjects cannot be faulted for using another communication channel to submit their requests. No detrimental consequence for the data subject can be drawn from the fact – even in the event that they were correctly informed – that they did not use the appropriate form or addressed the data controller through another means, such as an incorrect email address. In this case, the first defendant noted that complainant No. 1 had sent their deletion request to the general address of the platform and not to the address dedicated to exercising the right to erasure, but that this had no impact on the processing of their deletion request, as their data had been deleted. The Contentious Chamber notes that, except in exceptional cases, this is indeed the expected attitude of data controllers.

15 See the Guidelines of the EDPB on transparency (WP 260 of the Article 29 Working Party adopted by the EDPB during its inaugural session on May 25, 2018): <https://edpb.europa.eu/our-work-tools/our-documents/article-29-working-party-guidelines-transparency-under-regulation-en> and those relating to the right of access (Guidelines 01/2022) https://edpb.europa.eu/system/files/2023-04/edpb_guidelines

Decision on the merits 149/2023 — 21/34

II.4. Regarding the breach of Articles 5.1. a), 5.2., and 6 of the GDPR by the first defendant: the lawfulness basis for processing the data of unregistered healthcare professionals (DOS-2020-05649)

II.4.1. The viewpoint of the SI and the parties

85.

According to its investigation report, the SI concludes that the first defendant cannot rely on Article 6.1.f) of the GDPR as a lawful basis for processing the data of unregistered healthcare professionals, notably because it does not meet the balancing test (see below) in that "the publication of the contact details of these doctors on the Internet (whether by an official service such as the Crossroads Bank for Enterprises or not) does not allow them to reasonably expect that this data would be processed and, in this case, reproduced without their consent, on the website of a private company offering IT solutions to doctors for various subscription fees (...) (page 26 of the report)."

86.

Complainant No. 1 states that they fully support the SI's analysis.

87.

As for the first defendant, it primarily argues that this grievance should have been the subject of a separate procedure since it does not arise from the complaint filed by complainant No. 1. It is therefore inadmissible in its view.

88. In the alternative, the first defendant argues (1) that it pursues a legitimate interest (which consists of enabling patients to more easily contact the healthcare professionals of their choice), (2) that the data it processes regarding unregistered healthcare professionals is necessary for achieving the interest it pursues (namely, providing contact details for information and potential contact), and (3) that the balancing exercise it has conducted allows it to conclude that it can rely on this legitimate interest. The first defendant indicates that it has taken into account the public and professional nature of the data (taken from the Crossroads Bank for Enterprises (CBE) and Google), the absence of a manifest infringement of the privacy of the concerned practitioners or any other of their fundamental rights, the absence of harm in their physical, economic, or social situation (on the contrary, a benefit in terms of visibility would be provided), their reasonable expectations, and the existence of a right to object on their part. The result of this balancing allowed it to conclude that it satisfied the three tests of purpose (1), necessity (2), and balancing (3) required by Article 6.1.f) of the GDPR. The first defendant therefore argues that it could base the processing of the data of unregistered healthcare professionals on this lawful basis.

Decision on the merits 149/2023 — 22/34

II.4.2. The assessment of the Contentious Chamber

89.

With the SI, the Contentious Chamber is of the opinion that the question of the lawfulness basis for the processing of data of unregistered practitioners must, in this case, be considered as part of the scope of complaint no. 1 since (1) this question is raised – albeit in general terms – by complainant no. 1 in her complaint, (2) she had, even before filing it, questioned the first defendant on this matter without receiving a response, and (3) the request for erasure from complainant no. 1 is consequent to the fact that the dentist with whom she sought to make an appointment was precisely an unregistered health professional and that due to this lack of registration, complainant no. 1 was unable to make the intended appointment. The Contentious Chamber recalls that in any event, once seized, the SI may, in the exercise of its own competence, broaden the scope of its investigations.

90. As for the merits, the Contentious Chamber recalls that in order to rely on the lawfulness basis of "legitimate interest" under Article 6.1.f) of the GDPR, the data controller, namely the first defendant in this case, must demonstrate that a) the interest it pursues through the processing of the relevant data can be recognized as legitimate (the "purpose test"); b) that the intended processing is necessary to

achieve that interest (the "necessity test"); and c) that the balancing of that interest against the interests, freedoms, and fundamental rights of the data subjects weighs in its favor or in favor of the third party (the "balancing test").

91.

The Contentious Chamber will verify whether, in this case, these 3 tests are satisfied regarding the disputed processing, namely the provision on the platform of personal data of unregistered health professionals as previously specified, namely of health professionals whose name, first name, specialty, address, and professional phone number the first defendant has listed on the platform without the possibility of making an appointment with them through it.

Regarding the purpose test (a): is there a legitimate interest?

92.

The Contentious Chamber recalls that in order to be qualified as "legitimate," the interest pursued by the data controller (or the third party, but this is not the case here) must be lawful under the law, determined in a sufficiently clear and precise manner, be real and present (born and current) and not fictitious or hypothetical.

93.

By making the contact details of doctors and other health professionals available to users of the platform, even if their schedule is not linked to the platform, the first defendant pursues the objective of enabling patients to easily find and contact a healthcare professional by sharing necessary data for a potential contact with them (see also below). In doing so, the Contentious Chamber is of the opinion that the first defendant contributes to the right

Decision on the merits 149/2023 — 23/34

of each patient to access healthcare as well as their right to consult the practitioner (registered) of their choice as guaranteed by Article 6 of the Law of August 22, 2002, relating to patient rights. The data processing carried out by the first defendant thus falls within the pursuit of a legitimate societal interest coupled with an economic interest specific to the first defendant, which is also legitimate, based on the freedom of enterprise notably enshrined in Article 16 of the Charter of Fundamental Rights of the Union.

94.

In support of the above, the Contentious Chamber is of the opinion that the interest pursued by the first defendant is legitimate. Consequently, the "purpose test" of Article 6.1.f) of the GDPR has been satisfied.

Regarding the necessity test (b): is the processing necessary?

95.

Concerning the necessity test, the Contentious Chamber recalls that the Court of Justice of the European Union (CJEU) has ruled, among other things, in the "TK" judgment on this condition of necessity of processing, emphasizing the strict interpretation of this condition, which is not specific to Article 6.1.f) of the GDPR but common to all the lawful bases listed in Article 6.1 of the GDPR, except for consent provided for in Article 6.1.a).

96.

The CJEU also notes that the condition regarding the necessity of processing must be examined in conjunction with the so-called "data minimization" principle enshrined in Article 6, paragraph 1, under c), of Directive 95/46, which states that personal data must be "adequate, relevant, and not excessive in relation to the purposes for which they are collected and for which they are subsequently processed."

97.

The CJEU has also clarified that if there are realistic and less intrusive alternatives to the processing carried out, this processing is not "necessary." In other words, the data controller must ensure that there is no less intrusive means of achieving its objective than implementing the proposed processing (for example, a device that does not process).

17 "Regarding the second condition set out in Article 7, under f), of Directive 95/46, relating to the necessity of resorting to the processing of personal data for the realization of the legitimate interest

pursued, the Court recalled that exceptions and restrictions to the principle of the protection of personal data must operate within the limits of what is strictly necessary (judgment of May 4, 2017, *Rīgas satiksme*, C-13/16, EU:C:2017:336, paragraph 30 and case law cited).

18 This condition requires the referring court to verify that the legitimate interest of the data processing pursued by the surveillance in question, which essentially consists of ensuring the security of property and persons and preventing the occurrence of offenses, cannot reasonably be achieved as effectively by other means that are less intrusive to the freedoms and fundamental rights of the individuals concerned, particularly the rights to respect for private life and to the protection of personal data guaranteed by Articles 7 and 8 of the Charter." It is the Contentious Chamber that emphasizes this. Decision on the merits 149/2023 — 24/34

no personal data, or a different treatment that is more protective of the right to privacy and the protection of personal data of the data subject).

98.

This case law formulated in relation to Articles 7 and 6 of Directive 95/46/EC remains relevant to this day. Article 6.1 of the GDPR indeed reiterates the terms of Article 7 of Directive 95/46/EC - the legitimate interest of the data controller being retained (Article 7 f) and Article 6.1. f), albeit in somewhat different terms. Article 5.1. c) of the GDPR, related to the principle of minimization, reinforces the terms of Article 6.1.c) of Directive 95/46/EC to which the CJEU also refers. As the first defendant points out, the context of "video surveillance" in the *TK* judgment is certainly distinct from the context in which the disputed processing is situated in this case. However, this does not justify dismissing the principles set forth by the CJEU regarding the conditions of legitimate interest as a basis for lawfulness. These requirements are expressed in general terms applicable across all contexts.

99.

In this case, the Contentious Chamber is of the opinion that the processing of personal data of unregistered doctors is necessary to achieve the interest pursued by the first defendant through its platform, which consists of linking (future) patients and healthcare professionals. Regarding the data processed, the Contentious Chamber believes that the principle of minimization is respected: it is indeed a matter of providing users of the platform (patients) with limited and necessary information regarding the identity of the practitioner, their specialty (is it appropriate to make an appointment with them or not?), their geographical proximity or at least their location via their address (is it appropriate to contact them rather than another?), as well as their professional phone number (to allow for an appointment to be made, if necessary, via the platform but also directly via this number).

Regarding the balancing test (c):

100. The Contentious Chamber recalls that in addition to the two aforementioned conditions, Article 6.1. f) of the GDPR can only be invoked if the interests or the fundamental rights and freedoms of the data subject do not prevail over the interest pursued by the data controller or the third party. In other words, the data controller must carry out a balancing act, weighing the rights and interests at stake, and verify in this context that the interests (commercial, property security, combating fraud, etc.) it pursues do not create an imbalance to the detriment of the rights and interests of the individuals whose data is processed. If the interests and rights of the latter prevail, Article 6.1. f) of the GDPR cannot be used.

101. Concretely, the data controller must first identify the consequences of all kinds that its processing may have on the data subjects: on their private lives but also, more broadly, on all the rights and interests covered by the protection of personal data. It is thus a matter of assessing the degree of intrusion of the

Decision on the merits 149/2023 — 25/34

processing envisaged in the individual sphere, by measuring its impact on the private life of individuals (processing of sensitive data, processing concerning vulnerable persons, profiling, etc.) and on their

other fundamental rights (freedom of expression, freedom of information, freedom of conscience, etc.) as well as the other concrete impacts of the processing on their situation (monitoring or surveillance of their activities or movements, exclusion from access to services, etc.). These impacts must be measured in order to determine, on a case-by-case basis, the extent of the intrusion caused by the processing into the lives of individuals. The principle of data minimization will also be taken into account.

102. The data controller must then consider, in weighing its legitimate interest against the rights and interests of the individuals concerned, the "reasonable expectations" of those individuals. This consideration is essential for processing that can be carried out without the prior consent of the individuals: in the absence of a positive and explicit act on their part, the legitimate interest requires not to surprise individuals in the modalities of implementation as well as in the consequences of the processing.

103. In this case, the Contentious Chamber finds that the data processed are indeed publicly accessible and professional data. This nature of the processed data is a factor that can contribute to tipping the balance in favor of the data controller, provided that the individuals concerned can reasonably expect their data to be used for the purpose pursued by the said data controller and this, without their prior consent.

104. The Contentious Chamber is of the opinion that in this case, the disputed processing does not fall within the reasonable expectations of the concerned unregistered healthcare professionals. Their contact details are published on their own website or on that of their practice, or even on that of a hospital where they provide services. They have a direct link with this practice or hospital. The Contentious Chamber starts from the idea that they have expressed their agreement for these publications which fall within the framework of professional relationships they have themselves established. However, they cannot reasonably expect that their data will be republished on a platform such as that of the first defendant, which, beyond the "directory" function it offers for these unregistered healthcare professionals, pursues a more general commercial interest by offering various paid services, including the scheduling of appointments directly via the platform and the management of the electronic calendar. That the first defendant may have thought that increased visibility for healthcare professionals could be beneficial to them can certainly be understood. However, the Contentious Chamber concludes that in this case, the fact that the processing cannot be considered as falling within the reasonable expectations of these practitioners is decisive and tips the balance in favor of the rights and freedoms of the latter. Therefore, the "balancing test" is not satisfied.

Decision on the merits 149/2023 — 26/34

Conclusion

105. At the end of the analysis above, the Contentious Chamber concludes that there has been a violation of Article 5.1. a) (lawfulness requirement) and Article 6.1. of the GDPR by the first defendant in that it could not validly rely on the lawful basis of Article 6.1.f) of the GDPR to legitimize the processing of data of healthcare professionals not registered on its platform and therefore did not have a valid lawful basis to justify said processing.

II.5. Regarding the processing of the National Register Number (DOS-2020-05649 and DOS-2021-05271)

II.5.1. The parties' viewpoints

106. Both complainant No. 1 and complainant No. 2 denounce in their respective complaints the processing of the NRN by the first defendant and question the lawfulness of its processing in light of the LRN.

107. Complainant No. 1 highlights that, in principle, the use of the NRN is prohibited. Only the persons exhaustively listed in Article 5.1. of the LRN may use it, subject to authorization from the Minister of the Interior. By way of exception, Article 8.3. of the LRN provides that "an authorization to use the national register number is not required if the national register number is exclusively used for the identification and authentication of a natural person within the framework of a computer application offered by a private or public institution of Belgian law or by the authorities, institutions, and persons referred to in Article 5, § 1." Complainant No. 1 believes that the first defendant wrongly relies on this exemption since the patient's introduction of their NRN on the platform does not allow for identification or

authentication (the NRN seems rather to be used as a user number for the data subject), the first defendant not having access to the National Register or the patient's electronic identity card. Therefore, according to complainant No. 1, it should be considered that the first defendant processes the NRN of the platform users unlawfully.

108. As for the first defendant, it states in its conclusions that it opted for the NRN to identify and authenticate the users of the platform securely, as it is a unique identifier of which only the data subject has, in principle, knowledge (point 22). It deemed it essential, given the (health) data that could be exchanged through the platform between a patient and a healthcare professional, that the user be uniquely and reliably identified and authenticated. The first defendant indicates that it believed it could rely on the aforementioned Article 8.3. of the LRN while stating that it does not access the national register.

Decision on the merits 149/2023 — 27/34

109. During the hearing, the first defendant indicated, as already mentioned in point 28, that she had made the decision to refrain from requesting the National Registration Number (NRN) from users of the platform, thereby breaking with a choice that had been made at the time of the platform's creation by the previous management.

II.5.2. The assessment of the Contentious Chamber

110. Article 87 of the GDPR provides that "Member States may specify the specific conditions for the processing of a national identification number or any other identifier of general application. In this case, the national identification number or any other identifier of general application is only used subject to appropriate safeguards for the rights and freedoms of the data subject adopted under this Regulation."

111. Under Belgian law, the processing of the NRN, which constitutes such a national identification number, is strictly regulated in the aforementioned National Registration Law (LRN). Article 5 of the LRN exhaustively determines the authorities, bodies, organizations, or persons who may access it.

112. Article 8 of the LRN states the necessity of being, unless an exception applies, authorized by the Minister of the Interior to, as in this case, use this number. An exemption from authorization is provided if, as mentioned above, the NRN is exclusively used "for the purposes of identifying and authenticating a natural person within the framework of a computer application offered by a private or public institution under Belgian law or by the authorities, bodies, and persons referred to in Article 5, § 1."

113. As the Privacy Protection Commission (CPVP) emphasized in its opinion 19/2018 of February 28, 2018, concerning a draft law introducing, among other things, amendments to the LRN, including the aforementioned Article 8.3, "the authentication of a person consists of verifying that they have the identity they claim to have. It is the authentication certificate (including the national registration number) present on the electronic identity card that allows this through cryptographic techniques" (point 31 of the opinion).

114. In this case, it appears from the explanations provided by the first defendant herself that she was not identifying or authenticating the user of the platform based on the NRN that the latter was invited to provide. Indeed, the first defendant admits not accessing the National Register. She therefore does not verify, through access to the RN data and reading the electronic identity card, the authenticity of the information provided.

19 In accordance with Article 4.1 of the LCA, the Data Protection Authority (DPA) (and the Contentious Chamber) has the authority to monitor compliance with the National Registration Law: "The Data Protection Authority is responsible for monitoring compliance with the fundamental principles of the protection of personal data, within the framework of this law and laws containing provisions related to the protection of personal data processing."

20 The DPA succeeded the Privacy Protection Commission (CPVP) in execution of the Law of December 3, 2017, establishing the Data Protection Authority (LCA): Article 3.

21 Privacy Protection Commission, Opinion 19/2018 of February 28, 2018, regarding the draft law containing various provisions "Interior."

Decision on the merits 149/2023 — 28/34

the identity of the person nor verifies that this person is indeed who they claim to be. The first defendant only asks the patient to enter an "access code" (their NRN in this case) without verifying that

this code reveals their certain identity. It is by no means excluded that this person mentions an NRN that is not theirs, coupled with their real identity, which, without reading the electronic identity card, the first defendant will not be able to detect. While the Contentious Chamber shares the first defendant's analysis that strong identification and authentication are necessary given the processing of data (sensitive if applicable) that occurs via the platform, it nonetheless concludes that it is incorrect for the first defendant to assert that they were in the conditions for exemption under Article 8.3 of the LRN.

115. Thus, even in cases where, as in this instance, users of the platform consent to communicate their NRN, this consent, however compliant with the requirements of Articles 6 and 7 of the GDPR, is not sufficient to authorize its processing since the processing of the NRN must be lawful and comply with the provisions of the LRN, including its Articles 5 and 8. The Contentious Chamber concludes that, in the absence of the first defendant being in compliance with these provisions, they were not authorized to use this NRN and therefore to request it, in violation of Articles 5.1. a) and 6.1. of the GDPR read in conjunction with Article 8 of the LRN.

116. The Contentious Chamber has taken note of the first defendant's decision to refrain from requesting the NRN from users of the platform. It reminds that this change does not erase the past breach and must be reflected in the first defendant's Privacy Policy.

III. Regarding corrective measures and sanctions

117. Under Article 100 of the LCA, the Contentious Chamber has the power to:

- 1° dismiss the complaint;
- 2° order the dismissal;
- 3° pronounce a suspension of the ruling;
- 4° propose a settlement;
- 5° issue warnings or reprimands;
- 6° order compliance with requests from the data subject to exercise their rights;
- 7° order that the interested party be informed of the security issue;
- 8° order the freezing, limitation, or temporary or permanent prohibition of processing;
- 9° order compliance of the processing;

Decision on the merits 149/2023 — 29/34

- 10° order the rectification, restriction, or deletion of data and notification of such to the data recipients;
- 11° order the withdrawal of the accreditation of certification bodies;
- 12° impose penalties;
- 13° impose administrative fines;
- 14° order the suspension of cross-border data flows to another State or an international organization;
- 15° refer the case to the Public Prosecutor's Office of the King of Brussels, which informs it of the follow-up given to the case;
- 16° decide on a case-by-case basis to publish its decisions on the website of the Data Protection Authority.

III.1. Regarding the first defendant (DOS-2020-05649 and DOS-2020-05271)

III.1.1. The breaches

118. It follows from the above that the first defendant has committed a breach of Article 12.3 of the GDPR (point 65), Articles 5.1. a) (lawfulness) and 6.1 of the GDPR regarding the processing of data of unregistered healthcare professionals (point 105) as well as Article 5.1. a) (lawfulness) and 6.1. of the GDPR read in conjunction with Article 8 of the LRN regarding the processing of the NRN of users of the platform (point 115).

119. It is up to the Contentious Chamber to determine the most appropriate corrective measure and/or sanction for these breaches.

120. The Contentious Chamber specifies beforehand the following regarding the principle of "ne bis in idem" invoked by the first defendant concerning the complaint regarding the lawfulness of the processing of the NRN. The first defendant indeed expresses surprise at having been invited to conclude on this issue in the context of the two complaints (point 22) and stated during the hearing that they were questioning the respect of this principle by the Contentious Chamber if it were to sanction the same breach twice over the same period.

121. The Contentious Chamber recalls that the general legal principle "non bis in idem" entails that "no one can be prosecuted or punished a second time for an offense (even if otherwise qualified) for which they have already been acquitted or convicted by a final judgment in accordance with the law and the criminal procedure of each country." In other words, second prosecutions are prohibited for identical or substantially identical facts that, having been subject to previous prosecutions, have resulted in a final decision of acquittal or conviction. By "identical or substantially identical facts," one must understand a set of concrete factual circumstances related to a...

Decision on the merits 149/2023 — 30/34

the same suspect, which are inextricably linked in time and place (Cass., April 24, 2015, no. F.14.0045.N).

122. The respect due to this general principle of law does not in any way prevent the Contentious Chamber from inviting the concerned parties to defend themselves regarding the same grievance raised in different pending proceedings in which it has not yet made a decision. The Contentious Chamber is free to invite conclusions in a pending case following a complaint, even if subsequent to another that raises the same grievance during the same time period. It remains free to adopt its decisions according to the priority schedule it establishes. The Contentious Chamber adds that while in the specific case, the nature of the sanctions it imposes may, as the case may be, be classified as penal, this is not necessarily always the case.

123. In this instance, since the Contentious Chamber has not yet made any decision regarding either complaint no. 1 or complaint no. 2, it remained in any event free to invite the parties to conclude regarding the grievance of the legality of the processing of the NRN in the context of both complaints. Regarding the present decision, the Contentious Chamber has, as stated in point 51, decided to join complaints no. 1 and no. 2, notably in light of the common grievance they raised, as well as to adopt, as will be specified below, a single sanction regarding the breach identified in point 115 above.

III.1.2. The assessment of the appropriate sanction/corrective measure by the Contentious Chamber

124. In assessing the most appropriate sanction regarding the identified breaches, the Contentious Chamber takes into account the following elements specific to the case at hand. Thus, it considers the decisions and changes initiated by the first defendant who, both in its latest conclusions (point 27) and during the hearing (point 28), specified that following the Contentious Chamber's decision 75/2023, it had begun a process of obtaining consent from unregistered healthcare professionals. In the same vein, the first defendant decided to refrain from requesting the NRN of platform users at the time of account creation and presented a test version without this NRN during the hearing (point 28). The Contentious Chamber is also sensitive to the successive adaptations made by the first defendant to its Privacy Policy in a concern for constant improvement regarding the implementation of its obligations arising from the GDPR (points 60 and 68). Finally, the Contentious Chamber generally emphasizes the good cooperation of the first defendant both with itself and with the SI, notwithstanding Article 31 of the GDPR which requires such collaboration. However, all these elements are not sufficient to eliminate the breaches it has identified (point 118).

Decision on the merits 149/2023 — 31/34

125. On this basis, the Disciplinary Chamber is of the opinion that issuing a reprimand to the first defendant for the identified shortcomings is appropriate and takes into account both the reality of these shortcomings and the fact that they are attributable to a young start-up with a limited number of employees (2), which throughout the proceedings has shown a willingness to comply, has made a number of decisions in this regard, and has initiated operational changes consequent to these decisions.

126. The Disciplinary Chamber adds that, for the remainder, it is not required to explain the reasons why it does not impose a particular sanction, for example, one suggested by the complainant.

127. In this case, however, the Disciplinary Chamber wishes to respond to the fact that in its reply and summary conclusions, the first defendant argues that the Disciplinary Chamber would not be justified in imposing an administrative fine on the grounds that the fine is only the 13th sanction in the enumeration of Article 100 of the LCA, as well as based on the considerations expressed by the Market Court (CdM) in its judgment of January 27, 2021 (RG 2020/AR/1333, p.19), as well as those in which, in a judgment of May 26, 2021, the said Court would dismiss the possibility for the Disciplinary

Chamber to impose a fine from the first infringement committed inadvertently (GR 2021/AR/163).

128. The Disciplinary Chamber recalls that Article 58.2 of the GDPR states that each supervisory authority has the power to adopt all the corrective measures listed. The administrative fine is listed in the penultimate position (9th – *litera i*)), just before the 10th which allows for the suspension of flows. To consider that there is a form of hierarchy among the measures finds no support in the text of the GDPR; on the contrary, since *litera j*) specifies that each supervisory authority may impose an administrative fine in accordance with Article 83, in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case. Furthermore, the measure referred to in *litera j*) (suspension of flows) cannot, of course, be conditioned by the prior existence of a fine that would have been imposed. That would make no sense.

129. Regarding Article 100.1 of the LCA implemented under the GDPR, the same reasoning applies. It should be noted in this regard that the LCA does not reproduce the full terms of Article 58.2 of the GDPR, namely that the administrative fine may be ordered in addition to or instead of the measures referred to in this paragraph, depending on the specific characteristics of each case. Certainly, the fine is mentioned in 13th position in *litera 13*, but this must be read with the precision that has been omitted by the Belgian legislator. The measures referred to in *litera 14*, *15*, and *16* (publication of the decision) of Article 100.1 of the LCA are moreover not designed to only occur "after a fine."

130. In summary, the position of the fine in the list of corrective measures/sanctions provided for in the GDPR and the LCA does not mean, *a fortiori*, in support of the text of Article 58.2.i) of the...

Decision on the merits 149/2023 — 32/34

GDPR itself, which is a measure of last resort conditioned by the prior adoption of other corrective measures/sanctions - deemed less severe, even in the case of a first negligent breach²².

131. The Contentious Chamber adds that since the judgments cited by the first defendant, the CdM has revisited this position. The CdM has indeed subsequently provided more clarifications regarding the judgments cited by the first defendant, notably recalling the possibility of imposing a fine (and even a fine higher than the minimum amount of the range) on the data controller committing an infringement for the first time²³.

132. As already mentioned, the Contentious Chamber must, on the other hand, adopt the appropriate corrective measure and/or sanction in the specific case.

133. If the Contentious Chamber finds that the reprimand is an appropriate sanction in this case (point 125), the aforementioned decided changes must nonetheless be realized to put an end to the breaches reported under Articles 5.1. a) and 6 of the GDPR as quickly as possible. The CC therefore accompanies its reprimand with orders for compliance in accordance with the provisions below and a prohibition on processing the concerned data beyond a deadline set for January 15, 2024. It goes without saying that the first defendant must draw all consequences from this, for example, in terms of erasure of said data in the absence of a lawful basis that would authorize processing beyond this date and adapting its Privacy Policy.

134. The Contentious Chamber specifies that regarding the collection of consent from unregistered practitioners, the first defendant may seek the consent of each healthcare professional concerned by sending a personalized letter.

III.2. Regarding the second defendant (DOS-2020-05649)

135. The Contentious Chamber decides to adopt a decision of dismissal regarding the second defendant.

²² In its guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679 (WP 253 of the GDPR), the EDPB clarified in this regard that: "The assessment of the effectiveness, proportionality, and deterrent effect in each case must also take into account the objective pursued by the chosen corrective measure, namely to restore compliance with the rules or to sanction unlawful behavior (or both)." The EDPB also states that fines are an important tool that supervisory authorities should use in appropriate circumstances. Supervisory authorities are encouraged to adopt a well-considered and balanced approach when applying corrective measures to respond to the violation in a manner that is both effective and deterrent as well as proportionate. Fines should not be viewed as a last resort nor should there be a fear of imposing them; however, they

should also not be used in such a way that their effectiveness is diminished. See also Recital 148 of the GDPR.

23 See Market Court, July 7, 2021, 2021/AR/320, published on the website of the APD.

Decision on the merits 149/2023 — 33/34

136. In the case of dismissal, the Contentious Chamber must justify its decision step by step and:

- pronounce a technical dismissal if the file does not contain or does not contain sufficient elements likely to lead to a sanction or if it has a technical obstacle preventing it from making a decision;
- or pronounce an opportunistic dismissal, if despite the presence of elements likely to lead to a sanction, the continuation of the examination of the file does not seem appropriate to it given the priorities of the APD as specified and illustrated in the Contentious Chamber's Dismissal Policy.

137. In the case of dismissal based on several grounds (respectively, technical dismissal and/or opportunistic dismissal), the grounds for dismissal must be addressed in order of importance.

138. In the present case, the Contentious Chamber decides to proceed with a technical dismissal based on the absence of any breach of the GDPR or the laws for which it is responsible for ensuring compliance that can be established against the second defendant. Indeed, as it is neither a joint data controller nor a subcontractor, no breach is attributed to it in this case regarding the complaints raised against it by complainant No. 1.

139. Therefore, the Contentious Chamber dismisses complaint No. 1 for technical reasons based on Article 100.1.1° of the LCA.

IV. Publication of the decision

140. Given the importance of transparency regarding the decision-making process of the Contentious Chamber, this decision is published on the website of the Data Protection Authority (APD). However, it is not necessary for this purpose that the identification data of the parties be directly mentioned.